

Narrativa Explicativa — Por Qué Esta Encuesta, Por Qué Ahora y Por Qué España

El relato de un riesgo sistémico que ya no puede esperar

Versión 1.0 · Documento (c) del Kit de Encuesta CSCR

"Hay dos tipos de organizaciones: las que saben que han sido comprometidas a través de su cadena de suministro, y las que todavía no lo saben."

— Adaptación libre de un axioma del sector que, lamentablemente, mejora cada año en precisión estadística.

I. El Momento Exacto

Existe una cifra que, por sí sola, justifica la existencia de esta encuesta: **254 días**. Ese es el tiempo medio que transcurre entre el momento en que un atacante penetra en una organización a través de un proveedor comprometido y el momento en que esa organización lo detecta. Ocho meses, aproximadamente. El equivalente a dos auditorías trimestrales, tres renovaciones de contrato con el proveedor comprometido y alguna que otra presentación al Comité de Dirección sobre lo bien que va la ciberseguridad.

Este dato, documentado por Cipher/Grupo Prosegur en su análisis de 2026 sobre ataques a la cadena de suministro, no es una anomalía estadística. Es el promedio. Y se produce en un contexto en el que los ataques a la cadena de suministro se han **duplicado en 2025** respecto al año anterior, con un coste medio por incidente de 4,33 millones de euros y un coste global agregado de 53.200 millones de dólares anuales.

España, que presume —con razón— de ser el segundo país del mundo en centros de ciberseguridad y que en mayo de 2025 aprobó el mayor plan de inversión en ciberseguridad de su historia (1.157 millones de euros), sigue teniendo en la cadena de suministro su talón de Aquiles más predecible y menos atendido.

Este es el momento exacto para hacer la pregunta. Y esta encuesta es la herramienta.

II. La Anatomía del Problema

Para entender por qué la cadena de suministro se ha convertido en el vector de ataque preferido de los adversarios más sofisticados —desde grupos de ransomware con motivación económica hasta actores patrocinados por estados— conviene visualizar la geometría del problema.

Una organización mediana española gestiona, en promedio, entre 50 y 200 proveedores TIC con algún nivel de acceso a sus sistemas, redes o datos. Cada uno de esos proveedores tiene sus propios proveedores. Y los subcontratistas de esos proveedores tienen los suyos. El resultado es una red de dependencias de segundo y tercer nivel que ningún inventario convencional cartografía completamente. Los atacantes lo saben. Y actúan en consecuencia.

El 22,5% de todas las brechas de seguridad registradas en 2025 involucraron a terceros o proveedores como vector de entrada. Una de cada cuatro brechas no empieza en casa: empieza en casa del proveedor de las herramientas de monitorización, en el software de gestión del proveedor logístico, en el sistema de acceso remoto del mantenedor de los autómatas industriales. Y la organización afectada no lo sabrá durante, como mínimo, ocho meses.

El Foro Nacional de Ciberseguridad, en su informe de septiembre de 2025, lo articula con notable precisión: la imposibilidad de supervisar a todos los proveedores en ecosistemas con cientos de subcontratistas, la ausencia de un mecanismo de certificación universal y la regulación fragmentada y sectorial configuran un escenario de vulnerabilidad estructural que ninguna organización puede resolver individualmente.

III. El Contexto Normativo: La Ventana de Oportunidad y el Viento de Cola Regulatorio

España vive un momento normativo irrepetible. La Directiva NIS2 debía estar transpuesta en octubre de 2024; en abril de 2026 el proceso parlamentario del Anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad sigue su curso. La Comisión Europea ha iniciado un procedimiento de infracción. En el ínterin, más de 5.700 organizaciones españolas en sectores esenciales e importantes navegan en una zona de albedrío normativo que, como todo albedrío no elegido, tiene fecha de caducidad.

A ese proceso se suma la entrada en vigor progresiva del Cyber Resilience Act (CRA), con sus requisitos de SBOM para todos los productos con elementos digitales; de DORA, con sus exigencias de resiliencia operativa digital para el sector financiero; y del roadmap europeo de migración a criptografía post-cuántica, con hitos en 2026, 2030 y 2035.

El ENS —Esquema Nacional de Seguridad, actualizado en 2022— ya contiene controles explícitos para la cadena de suministro: la figura del POC (*Punto de Contacto*) para servicios externalizados, los controles op.ext para proveedores cloud y la exigencia de que los proveedores de primer nivel garanticen que sus subcontratistas también cumplen. Son controles exigibles. Y su tasa de implementación real es, según todos los indicios disponibles, significativamente inferior a lo que los informes de cumplimiento reflejan.

El cuestionario unificado publicado en febrero de 2025 por la alianza CCN-CERT/ISMS Forum Spain es la primera iniciativa práctica nacional que traduce esa complejidad normativa en un instrumento operativo. Es también la señal más clara de que el ecosistema español está listo para una medición sistemática.

IV. Por Qué una Encuesta: El Valor del Diagnóstico Colectivo

Una de las paradojas más reveladoras que documentan los datos europeos de ENISA en su informe NIS Investments 2025 es la siguiente: el 90% de las organizaciones NIS2 declara implementar controles de seguridad orientados a proveedores, pero el 37% señala el CSCRM como el área más difícil de cumplir en NIS2. La brecha entre la existencia formal de controles y su eficacia operativa es la grieta real del sistema.

Esta encuesta no pretende verificar el cumplimiento declarado. Pretende algo más ambicioso y más útil: medir la brecha entre el control que existe en el papel y el control que funciona en la práctica; identificar los patrones de madurez que diferencian a las organizaciones resilientes de las vulnerables; y proporcionar a cada organización participante un espejo de posicionamiento relativo frente a su sector y tamaño.

El diagnóstico colectivo tiene también una dimensión de política pública que trasciende a cada organización individual. Los resultados agregados de esta encuesta informarán —se espera y se propone— las deliberaciones del Foro Nacional de Ciberseguridad, las recomendaciones de CCN-CERT e INCIBE y el diseño de los futuros programas de apoyo a las organizaciones en su camino de madurez CSCRM.

V. Las Preguntas que Esta Encuesta Formula (y Las que No)

Esta encuesta formula 55 preguntas estructuradas organizadas en 12 bloques. Algunas son incómodas por diseño. Preguntar cuánto tiempo tardó la organización en detectar el último incidente originado en un proveedor es incómodo, porque la respuesta honesta a menudo revela una capacidad de detección que ningún director de ciberseguridad exhibiría en una licitación. Preguntar si se tienen accesos activos de proveedores con contratos finalizados es incómodo, porque la respuesta afirmativa —más frecuente de lo que se reconoce públicamente— implica una vulnerabilidad explotable en este momento.

La incomodidad está diseñada. Los estudios de madurez que solo formulan preguntas cómodas producen resultados cómodos e inútiles.

Lo que esta encuesta no pretende es auditar, certificar ni sancionar. Es un instrumento de investigación y aprendizaje, no de fiscalización. Las respuestas son confidenciales. El único juez es la organización encuestada frente a sus propios objetivos y frente al espejo del benchmark sectorial.

VI. La Estructura Narrativa de la Encuesta

Los once bloques temáticos de la encuesta siguen una lógica narrativa deliberada:

El prólogo (Bloque 0) establece el contexto: quién responde, desde qué organización, con qué tamaño y en qué sector. Sin este contexto, las respuestas son datos; con él, son información.

El primer acto (Bloques I–II) examina los fundamentos: ¿existe una estrategia? ¿Se sabe qué proveedores existen y cuáles son críticos? Sin inventario, sin política y sin responsable, todo lo que sigue es edificar sobre arena.

El segundo acto (Bloques III–IV) evalúa los mecanismos: ¿qué se exige contractualmente? ¿Cómo se supervisa? ¿Cómo se mide el comportamiento del proveedor? Este es el núcleo operativo del CSCRM: la diferencia entre tener un proveedor gestionado y tener un proveedor registrado.

El tercer acto (Bloques V–VI) aborda la resiliencia: ¿qué ocurre cuando algo falla? ¿Está el proveedor en el plan de respuesta? ¿Se ha probado? La resiliencia no es un accidente; es la consecuencia predecible de haber ensayado.

El cuarto acto (Bloques VII–IX) mira hacia el horizonte: SBOM, criptografía post-cuántica, modelos de IA, Zero Trust, intercambio de información. Estas son las fronteras que el CSCRM deberá incorporar en los próximos 24-36 meses. Quienes las anticipen ahora tendrán ventaja. Quienes las descubran cuando sean obligatorias, tendrán urgencia.

El epílogo (Bloques X–XI) cierra el ciclo con reflexión estratégica: dónde está la organización, qué obstáculos enfrenta, qué prioriza. Y la pregunta final abierta: ¿qué quiere añadir que las preguntas estructuradas no han capturado?

Porque los mejores insights de cualquier encuesta siempre aparecen en el campo libre.

VII. Lo Que Esta Encuesta No Puede Resolver (Pero Puede Iniciar)

Esta encuesta no resolverá el problema de la cadena de suministro en España. Ninguna encuesta lo hace. Lo que puede hacer —y lo que se propone explícitamente— es iniciar tres conversaciones que actualmente no tienen datos suficientes para sostenerse:

La conversación con los reguladores: sobre cuáles son las brechas más críticas que los marcos normativos vigentes no abordan adecuadamente, y dónde la guía técnica es insuficiente o inaccesible.

La conversación entre iguales: sobre qué prácticas funcionan en organizaciones similares, qué herramientas aportan valor real versus las que generan informe sin acción, y cómo las organizaciones de menor tamaño pueden alcanzar niveles de madurez que actualmente parecen reservados a las grandes corporaciones.

La conversación interna: la que cada organización debe tener consigo misma cuando termina de cumplimentar esta encuesta y ve su puntuación IGM. Esa conversación —entre el CISO y el CEO, entre Compras y Seguridad, entre la aspiración a la resiliencia y la realidad del presupuesto disponible— es el verdadero producto de este instrumento.

VIII. Una Nota Sobre el Tono

El lector atento habrá observado que esta encuesta no se escribe en el tono aséptico habitual de los cuestionarios de cumplimiento normativo. Hay notas al pie que hacen guiños. Hay opciones de respuesta que reconocen la realidad con cierta ironía. Hay un epígrafe que recuerda que "los mejores insights siempre aparecen en el campo libre".

Esta elección es deliberada y tiene respaldo metodológico. Los estudios muestran consistentemente que los cuestionarios que generan algún tipo de implicación emocional o narrativa obtienen tasas de respuesta más altas, respuestas más honestas y mayor tasa de cumplimentación de los campos abiertos. La ironía amable no es un adorno estilístico: es una estrategia para que la encuesta sea leída hasta el final y respondida con la atención que merece.

El problema CSCRM es serio. El instrumento para medirlo puede ser, también, interesante de responder.

© 2026 · *Narrativa Explicativa CSCRМ España · Documento (c) del Kit de Encuesta*

Elaborada a partir del informe CSCRМ España 2025-2026 y de las fuentes primarias citadas en el mismo.